

1er •

Agosto 2026

Encuentro Nacional de Autoridades de
Simplificación y Digitalización

Ciberseguridad

Protección de datos ciudadanos
y protocolos ante incidentes

Autoridades estatales | DGCiber · ATDT

Enfoque preventivo



Gobierno de
México

Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones

La ciberseguridad acompaña la simplificación:

no es un trámite adicional,
es una condición de
confianza pública.

La digitalización local concentra datos de alta sensibilidad en servicios expuestos a Internet: identidad, salud, movilidad, predial, catastro, licencias, nómina, pagos y atención ciudadana.

Estados y municipios tienen la responsabilidad operativa de sus activos.

DGCiber aporta metodología, formatos de trabajo, criterios técnicos y webinar puntual de IDOR.

Marco de trabajo:

Colaboración

Prevención

Respuesta
coordinada



El problema no es solo *hackeo*:

es la exposición acumulada de datos ciudadanos en servicios digitales locales.

1

Datos ciudadanos

CURP, RFC, domicilio, teléfono, georreferencias, expedientes.

2

Trámites críticos

Pagos, licencias, predial, catastro, atención ciudadana.

3

Proveedores

Plataformas externas y desarrollos heredados sin controles homogéneos.

4

APIs/portales

Consultas por folio, ID, expediente o identificador predecible.

5

Respuesta inicial

Ventana de contención y comunicación durante las primeras 72 horas.

Reducir superficies de exposición, verificar autorización a nivel objeto
y **preparar respuesta coordinada ante incidentes.**

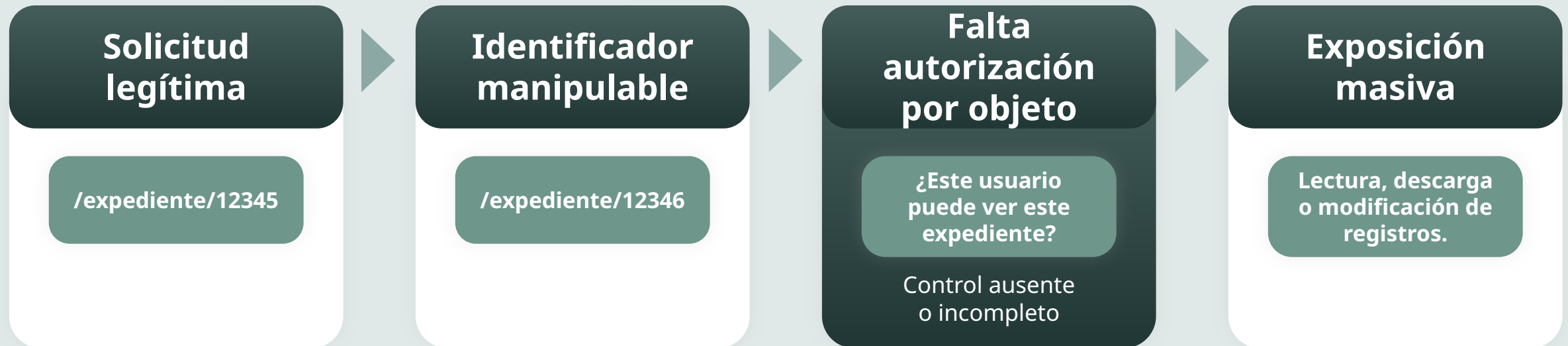
Incidentes públicos identificados: Estados y Municipios



Muestra de incidentes documentados en fuentes abiertas;
el vector técnico no siempre fue confirmado públicamente.

Asunto	Año	Tipo reportado	Impacto ciudadano/institucional
Sinaloa/Culiacán	2026	Filtración de bases de datos	>900 mil personas; trabajadores, contribuyentes y avalúos
Sinaloa/Culiacán	2026	Sistema de Atención Ciudadana	~250 mil registros ciudadanos; domicilios/teléfonos
Cajeme, Son.	2025	Ransomware municipal	Servicios digitales suspendidos; rescate reportado
Ahome, Sin.	2025	Exposición de funcionarios	2,085 registros con datos personales
Guanajuato FGE	2025-2026	Ransomware / exfiltración	Expedientes, datos operativos y documentos sensibles
Sonora Hacienda	2025	Robo de documentos	~40 GB de información gubernamental

Una persona autenticada o un actor externo **modifica un identificador y accede a información que no le corresponde.**



Regla técnica mínima

cada operación de lectura, descarga, edición o borrado debe validar autorización en servidor para el objeto solicitado, no solo que el usuario esté autenticado.

Los puntos críticos suelen estar en **consultas, descargas y APIs** que operan con identificadores.

Trámites por folio

Licencias, constancias, citas, solicitudes.

Catastro/predial

Cuenta, clave catastral, avalúos, historial de pagos.

Atención ciudadana

Reportes, quejas, coordenadas, domicilios.

Expedientes

Salud, desarrollo social, justicia cívica, permisos.

Documentos descargables

PDF, imágenes, recibos, acuses, anexos.

APIs móviles

App ciudadana, autenticación social, tokens débiles.

Indicador de riesgo

si al cambiar un ID, folio, usuario, placa, CURP, RFC o ruta se obtiene información de un tercero, el control de autorización por objeto falló.

Matriz de priorización para estados y municipios



Gobierno de
México

Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones

Primero se atiende donde coinciden datos sensibles, exposición a Internet y operación crítica.

Impacto ciudadano alto

	Hardening y monitoreo Portales con login, proveedores, APIs con consumo recurrente.
Revisión técnica programada Transparencia · Contenido público Trámites sin datos sensibles.	Prioridad inmediata Catastro · Predial · Atención ciudadana Licencias · Pagos.

Exposición técnica alta

Prioridad 1

Datos personales + consulta o descarga por identificador + exposición pública.

Prioridad 2

Sistemas internos con volumen alto de datos y acceso remoto o proveedor.

Prioridad 3

Portales informativos y servicios con baja sensibilidad, pero expuestos.

Protocolo mínimo ante incidente: primeras 72 horas



La respuesta debe preservar evidencia, contener daño y
sostener la continuidad del servicio público.

0-4 horas

Activar comité de incidente

TIC, jurídico, datos personales, comunicación social, área dueña del servicio.

4-12 horas

Contener sin destruir evidencia

Aislar, revocar credenciales, preservar logs, snapshots y cadena de custodia.

12-24 horas

Determinar alcance inicial

Sistemas, bases, datos, usuarios afectados, proveedor, vector probable.

24-48 horas

Comunicar y coordinar

Aviso interno, autoridades competentes, mensajes a ciudadanía si procede.

48-72 horas

Plan de recuperación segura

Remediar causa raíz, validar no persistencia, retorno controlado a operación.

No negociar, pagar o restaurar sin control técnico y jurídico.

No borrar logs, reinstalar o "limpiar" antes de preservar evidencia.

No volver a producción sin validar causa raíz y accesos.

Controles inmediatos contra IDOR y exposición de datos



Gobierno de
México

Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones

Un paquete de control de 30 días puede **reducir de manera sensible el riesgo en servicios vigentes.**

1 Inventario de URLs y APIs

Identificar dominios, subdominios, endpoints, apps móviles y servicios de terceros.

2 Pruebas con identidades

Usuario A no debe leer, modificar ni descargar objetos de Usuario B.

3 Autorización en backend

Validar permisos por objeto en servidor; no confiar en UI, token o ruta.

4 Registro y alertas

Log de consultas, descargas masivas, errores 403/404 y enumeración de IDs.

5 Mínima exposición

Retirar sistemas no vigentes, ocultar datos innecesarios y limitar exportaciones.

6 Evidencia de corrección

Ticket, commit, captura, resultado de prueba y fecha de validación.

Resultado esperado

cada sistema queda como vigente y revisado, no vigente y retirado, retirado previamente confirmado o pendiente de regularización.

**Una ruta
práctica,**
con bajo costo
de entrada y alto
valor preventivo.

- 1** **Inventario** Dominios, sistemas, responsables.
- 2** **Clasificación** Vigente, no vigente, crítico.
- 3** **Revisión técnica** IDOR, accesos, exposición.
- 4** **Remedicación** Baja, corrección, hardening.
- 5** **Canal de incidente** 72 horas, evidencia, coordinación.

DGCiber
acompaña con:

formato de inventario, checklist
IDOR y webinar puntual de IDOR.

Acuerdo de trabajo propuesto



Gobierno de
México

Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones

Tres productos sencillos para **cerrar brechas sin detener la transformación digital**.

Producto 1

Inventario de superficie digital local

Listado de dominios, subdominios, APIs, sistemas y responsables; incluye estatus vigente/no vigente.

Producto 2

Checklist IDOR por sistema crítico

Validación con dos identidades, evidencia de acceso permitido/denegado y remediación cuando aplique.

Producto 3

Protocolo de incidente de 72 horas

Roles, contactos, preservación de evidencia, comunicación, contención y retorno seguro.

Proteger datos ciudadanos es preservar la confianza pública en la simplificación y digitalización.

1er •

Agosto 2026

Encuentro Nacional de Autoridades de
Simplificación y Digitalización

Gracias



Gobierno de
México

Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones